Modelo de Amenazas - Microsoft Dynamics 365 F&O (Finanzas y Compras)

Propietario: [Nombre del estudiante]
Revisor:
Colaboradores: [Nombre del estudiante]
Generado en fecha: Sat Oct 10 2026

Resumen Ejecutivo

Descripción de alto nivel del sistema (high level system)

Modelo de amenazas STRIDE de una implementacion de referencia de D365 F&O (Finanzas y Compras) con Entra ID, integracion bancaria (Logic Apps / Service Bus) y Power BI. Curso: Seguridad en Aplicaciones - Maestria en Seguridad Informatica, UMG.

Resumen

Total amenazas	31
Total amenazas mitigadas	0
No Mitigadas	31
Abierto / Crítica Prioridad	6
Abierto / Alta Prioridad	13
Abierto / Prioridad Media	10
Abierto / Baja Prioridad	2

DFD Nivel 0 - Contexto

EE01 Usuario de Contabilidad (Actor)

Descripción: Registra asientos, facturas y pagos; concilia.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

EE02 Usuario de Compras (Actor)

Descripción: Gestiona órdenes de compra y proveedores.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

EE03 Administrador D365 (Actor)

Descripción: Administra roles, configuración y seguridad.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

EE05 Analista BI (Actor)

Descripción: Consume reportes financieros.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

EE04 Proveedor externo (Actor)

Descripción: Confirma órdenes de compra y envía facturas por el portal.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

EE06 Banco (Actor)

Descripción: Recibe instrucciones de pago y entrega extractos.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P00 Solución ERP D365 F&O (Finanzas y Compras) (Proceso)

Descripción: Sistema completo: identidad, aplicación, datos, integración y reportes.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F0-01 Transacciones contables y pagos (Flujo de datos)

Descripción: Transacciones contables y pagos

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F0-02 Órdenes de compra y datos de proveedor (Flujo de datos)

Descripción: Órdenes de compra y datos de proveedor

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F0-03 Configuración, roles y seguridad (Flujo de datos)

Descripción: Configuración, roles y seguridad

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F0-04 Consulta de reportes financieros (Flujo de datos)

Descripción: Consulta de reportes financieros

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F0-05 Confirmaciones de OC y facturas (Flujo de datos)

Descripción: Confirmaciones de OC y facturas

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F0-06 Instrucciones de pago, acuses y extractos (Flujo de datos)

Descripción: Instrucciones de pago, acuses y extractos

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

DFD Nivel 1 - Procesos, almacenes y trust boundaries

EE01 Usuario de Contabilidad (Actor)

Descripción: Registra asientos, facturas y pagos; concilia.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

EE02 Usuario de Compras (Actor)

Descripción: Gestiona órdenes de compra y proveedores.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

EE03 Administrador D365 (Actor)

Descripción: Administra roles, configuración y seguridad.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
8	T08 [Medio] Cambios administrativos sin atribución clara	Repudiation	Media	Abierto		Cambios de configuración, roles o parámetros realizados por administradores sin evidencia atribuible. (Impacto: Alto; Probabilidad: Baja; Riesgo: Medio).	Preventivo: Gestión de cambios con aprobación; PIM con justificación; registro de actividad administrativa. Detectivo: Alertas sobre cambios de configuración y de roles. Correctivo: Revertir los cambios y revisar el registro administrativo.

EE05 Analista BI (Actor)

Descripción: Consume reportes financieros.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
21	T21 [Bajo] El analista BI niega haber exportado o compartido informes	Repudiation	Baja	Abierto		Sin registro de actividad atribuible, no se puede demostrar quién exportó o compartió datos. (Impacto: Medio; Probabilidad: Baja; Riesgo: Bajo).	Preventivo: Habilitar registros de actividad de Power BI; cuentas nominales. Detectivo: Revisión periódica de la actividad de exportación. Correctivo: Consultar los registros y ajustar permisos.

EE04 Proveedor externo (Actor)

Descripción: Confirma órdenes de compra y envía facturas por el portal.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
2	T02 [Crítico] Suplantación de proveedor externo en el portal de colaboración	Spoofing	Crítica	Abierto		Un tercero toma control de una cuenta de proveedor (credenciales débiles o reutilizadas) para confirmar órdenes falsas, cargar facturas fraudulentas o solicitar un cambio de cuenta bancaria. (Impacto: Alto; Probabilidad: Alta; Riesgo: Crítico).	Preventivo: Cuentas invitadas (Entra B2B) con MFA obligatorio; verificación fuera de banda para cambios de datos bancarios; revisión periódica de cuentas externas. Detectivo: Alertas por cambios de datos bancarios del proveedor; monitoreo de inicios de sesión externos anómalos. Correctivo: Deshabilitar la cuenta, revertir cambios y validar facturas y pagos afectados con el proveedor real.

EE06 Banco (Actor)

Descripción: Recibe instrucciones de pago y entrega extractos.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P01 Microsoft Entra ID (Proceso)

Descripción: Autenticación, MFA, acceso condicional y emisión de tokens.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
1	T01 [Crítico] Suplantación de usuarios financieros por phishing/AiTM y fatiga de MFA	Spoofing	Crítica	Abierto		Un atacante obtiene credenciales o tokens de sesión de usuarios con roles de Finanzas o Compras (phishing con proxy inverso, robo de token o bombardeo de notificaciones MFA) y accede a D365 como usuario legítimo. (Impacto: Crítico; Probabilidad: Alta; Riesgo: Crítico).	Preventivo: MFA resistente a phishing (FIDO2/passkeys, number matching); acceso condicional (dispositivo conforme, ubicación, riesgo de sesión); protección de tokens; capacitación anti-phishing. Detectivo: Alertas de Entra ID Protection por inicios de sesión riesgosos; correlación de inicios de sesión en el SIEM; alertas de viaje imposible. Correctivo: Revocar sesiones y tokens, restablecer credenciales y MFA, revisar la actividad en D365 y contener el dispositivo.
4	T04 [Alto] Compromiso de cuenta administrativa con privilegios permanentes	Elevation of privilege	Alta	Abierto		Las cuentas de administrador con privilegios permanentes concentran el control de roles, configuración y seguridad; su compromiso permite escalar a control total de la implementación. (Impacto: Crítico; Probabilidad: Media; Riesgo: Alto).	Preventivo: Privileged Identity Management (acceso justo a tiempo); cuentas administrativas separadas; estaciones de trabajo privilegiadas; cuentas de emergencia protegidas y monitoreadas. Detectivo: Alertas de activación y uso de roles privilegiados; revisión de cambios de roles en el SIEM. Correctivo: Revocar roles y credenciales, rotar secretos, revisar cambios recientes de configuración y restaurar valores seguros.

P02 D365 F&O - Finanzas (Proceso)

Descripción: Cuentas por pagar, libro mayor, pagos y conciliación.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
3	T03 [Crítico] Violación de segregación de funciones por acumulación de roles	Elevation of privilege	Crítica	Abierto		Usuarios con combinaciones de roles (por ejemplo, crear proveedor, registrar factura y liberar pago) pueden ejecutar un fraude de extremo a extremo sin control cruzado. (Impacto: Crítico; Probabilidad: Alta; Riesgo: Crítico).	Preventivo: Reglas de segregación de funciones (SoD) en D365; rol mínimo necesario; revisiones trimestrales de acceso; aprobación por workflow. Detectivo: Reportes de conflictos SoD; alertas por pagos creados y liberados por el mismo usuario; auditoría interna. Correctivo: Retirar roles en conflicto, revertir transacciones sospechosas y abrir investigación.
7	T07 [Alto] Negación de aprobaciones y pagos por trazabilidad insuficiente	Repudiation	Alta	Abierto		Sin registro suficiente de quién aprobó, modificó o liberó transacciones, un usuario puede negar su participación y no hay evidencia para auditoría. (Impacto: Alto; Probabilidad: Media; Riesgo: Alto).	Preventivo: Cuentas nominales (sin cuentas compartidas); database logging en tablas críticas; aprobaciones con registro de usuario y fecha; retención de logs según política. Detectivo: Revisión periódica de bitácoras; pruebas de auditoría interna sobre trazabilidad. Correctivo: Reconstruir evidencia desde logs de Entra ID y D365; ajustar la configuración de auditoría.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
12	T12 [Alto] Indisponibilidad de D365 durante cierres contables	Denial of service	Alta	Abierto		Saturación por integraciones sin control de tasa, procesos por lotes concurrentes o incidentes del servicio impiden operar durante cierres y fechas de pago. (Impacto: Alto; Probabilidad: Media; Riesgo: Alto).	Preventivo: Gestión de límites y priorización de integraciones (throttling); programación de lotes fuera de horarios pico; plan de continuidad con procedimientos manuales. Detectivo: Monitoreo de Service Health y de latencia; alertas de errores de integración. Correctivo: Pausar integraciones no críticas, escalar con soporte de Microsoft y activar el plan de continuidad.

P03 D365 F&O - Compras (Proceso)

Descripción: Órdenes de compra, proveedores y portal de colaboración.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
5	T05 [Crítico] Alteración de datos maestros de proveedores (cuenta bancaria)	Tampering	Crítica	Abierto		Modificación no autorizada de datos maestros (cuenta bancaria, beneficiario) por fraude interno, cuenta comprometida o ingeniería social, con el fin de desviar pagos. (Impacto: Crítico; Probabilidad: Alta; Riesgo: Crítico).	Preventivo: Workflow de aprobación para cambios en datos maestros; doble control; verificación por llamada a un contacto conocido; restricción de roles de mantenimiento de proveedores. Detectivo: Reporte de cambios de cuentas bancarias; alerta cuando un cambio es seguido por un pago en pocos días; database logging en tablas de proveedores. Correctivo: Bloquear al proveedor, revertir el cambio, recuperar fondos con el banco y revisar pagos recientes.

P04 Integración bancaria (Proceso)

Descripción: Middleware que envía lotes de pago y recibe extractos.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
13	T13 [Alto] Interrupción de la integración bancaria	Denial of service	Alta	Abierto		Colas saturadas, certificados vencidos o fallos del middleware detienen el envío de pagos o la recepción de extractos. (Impacto: Alto; Probabilidad: Media; Riesgo: Alto).	Preventivo: Monitoreo de vencimiento de certificados; colas con reintentos y DLQ; redundancia y runbooks de contingencia (carga manual segura en banca en línea). Detectivo: Alertas por mensajes en DLQ, fallos de ejecución y expiración próxima de certificados. Correctivo: Reprocesar mensajes, renovar certificados y activar el procedimiento de contingencia.
14	T14 [Alto] Identidad de servicio (app registration) sobre-privilegiada o con secreto expuesto en OData	Spoofing	Alta	Abierto		La aplicación que consume las APIs OData y de administración de datos de D365 puede suplantarse si su secreto se filtra o si tiene permisos excesivos. (Impacto: Alto; Probabilidad: Media; Riesgo: Alto).	Preventivo: Autenticación con certificado o identidad administrada; permisos mínimos en D365 para la aplicación; restricción por IP/red; API Management con límites de tasa. Detectivo: Alertas por uso inusual del principal de servicio; revisión de inicios de sesión de aplicaciones. Correctivo: Rotar secretos o certificados de la aplicación, revocar consentimientos y revisar las llamadas realizadas.

P05 Power BI Service (Proceso)

Descripción: Reportes y paneles financieros.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
10	T10 [Crítico] Fuga de datos financieros mediante Power BI	Information disclosure	Crítica	Abierto		Informes o conjuntos de datos compartidos con exceso de permisos, publicación pública o exportaciones sin etiquetas exponen información financiera confidencial. (Impacto: Alto; Probabilidad: Alta; Riesgo: Crítico).	Preventivo: Deshabilitar 'Publicar en la web'; seguridad a nivel de fila (RLS); etiquetas de sensibilidad; permisos de workspace mínimos; gobierno de compartición. Detectivo: Registros de actividad de Power BI; alertas DLP; revisión de compartición externa. Correctivo: Quitar el acceso, retirar el contenido publicado y notificar al propietario del dato.

DS01 Base de datos de D365 (Dispositivo de almacenamiento)

Descripción: Datos financieros, de compras y maestros de proveedores.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
9	T09 [Alto] Exposición de datos financieros y de proveedores por permisos excesivos y exportaciones	Information disclosure	Alta	Abierto		Usuarios con permisos amplios o exportaciones a Excel y archivos pueden extraer información sensible (cuentas bancarias, datos personales, montos) fuera de los controles del ERP. (Impacto: Crítico; Probabilidad: Media; Riesgo: Alto).	Preventivo: Seguridad por roles de menor privilegio; restricciones de exportación; etiquetas de sensibilidad y DLP (Microsoft Purview); enmascaramiento de campos sensibles donde aplique. Detectivo: Auditoría de exportaciones masivas; alertas DLP; revisión de accesos a datos sensibles. Correctivo: Revocar accesos, recuperar o eliminar copias exportadas y notificar según la política de incidentes.
20	T20 [Medio] Pérdida o corrupción de datos sin recuperación oportuna	Denial of service	Media	Abierto		Errores masivos, importaciones defectuosas o ransomware en endpoints pueden dañar datos sin un plan de recuperación probado. (Impacto: Alto; Probabilidad: Baja; Riesgo: Medio).	Preventivo: Copias y restauración gestionadas por Microsoft; pruebas de recuperación; validaciones previas a importaciones masivas; entornos de prueba. Detectivo: Monitoreo de volúmenes anómalos de cambios y de errores de importación. Correctivo: Restaurar el entorno según el RPO/RTO acordado y conciliar los datos.

DS02 Azure Key Vault (Dispositivo de almacenamiento)

Descripción: Certificados y credenciales de la integración bancaria.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
11	T11 [Alto] Exposición de certificados y credenciales bancarias en Key Vault	Information disclosure	Alta	Abierto		Permisos amplios en Key Vault o secretos copiados en configuraciones permiten usar o robar certificados de firma y credenciales de conexión con el banco. (Impacto: Crítico; Probabilidad: Media; Riesgo: Alto).	Preventivo: RBAC de menor privilegio; identidades administradas en lugar de secretos; private endpoints; purge protection y rotación de secretos. Detectivo: Alertas por accesos a secretos fuera de patrón; registros de diagnóstico de Key Vault enviados al SIEM. Correctivo: Revocar y rotar certificados y credenciales; coordinar con el banco el reemplazo de claves.

DS03 Log Analytics / SIEM (Dispositivo de almacenamiento)

Descripción: Registros de auditoría y de integración.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
18	T18 [Medio] Exposición de datos sensibles en logs	Information disclosure	Media	Abierto		Los logs de integración o aplicación pueden contener datos personales, tokens o datos bancarios accesibles a más personas de las necesarias. (Impacto: Medio; Probabilidad: Media; Riesgo: Medio).	Preventivo: Enmascaramiento de datos sensibles en logs; RBAC mínimo en Log Analytics; política de retención. Detectivo: Revisiones periódicas de accesos a logs; escaneo de datos sensibles. Correctivo: Depurar los logs afectados y restringir accesos.
19	T19 [Medio] Manipulación o borrado de logs para ocultar actividad fraudulenta	Tampering	Media	Abierto		Un atacante o administrador malicioso elimina o altera registros para borrar evidencia. (Impacto: Alto; Probabilidad: Baja; Riesgo: Medio).	Preventivo: Reenvío inmediato al SIEM; almacenamiento inmutable; roles de logs separados de los administradores de la aplicación; retención mínima definida. Detectivo: Alertas por eliminación o cambios de configuración de logging; monitoreo de brechas en la telemetría. Correctivo: Reconstruir evidencia desde fuentes secundarias y reforzar permisos.

DS04 Modelo semántico Power BI (Dispositivo de almacenamiento)

Descripción: Conjunto de datos de reportes financieros.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
17	T17 [Bajo] Alteración del modelo semántico que distorsiona reportes financieros	Tampering	Baja	Abierto		Cambios no autorizados en medidas o relaciones del modelo producen cifras erróneas en los reportes. (Impacto: Medio; Probabilidad: Baja; Riesgo: Bajo).	Preventivo: Control de versiones y despliegue controlado; permisos de edición restringidos. Detectivo: Revisión de cambios en el modelo; reconciliación con las cifras del ERP. Correctivo: Restaurar la versión previa y comunicar la corrección.

F1-01 Credenciales y MFA (Flujo de datos)

Descripción: Credenciales y MFA

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-02 Credenciales y MFA (Flujo de datos)

Descripción: Credenciales y MFA

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-03 Credenciales privilegiadas y MFA (Flujo de datos)

Descripción: Credenciales privilegiadas y MFA

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-04 Credenciales de proveedor (invitado) (Flujo de datos)

Descripción: Credenciales de proveedor (invitado)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-05 Token OIDC / claims (Flujo de datos)

Descripción: Token OIDC / claims

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-06 Token OIDC / claims (Flujo de datos)

Descripción: Token OIDC / claims

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-07 Transacciones contables y pagos (Flujo de datos)

Descripción: Transacciones contables y pagos

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
6	T06 [Alto] Manipulación de transacciones en tránsito o desde un navegador comprometido	Tampering	Alta	Abierto		Alteración de importes, cuentas o beneficiarios mediante malware en el equipo del usuario, extensiones maliciosas o intercepción en redes no confiables. (Impacto: Alto; Probabilidad: Media; Riesgo: Alto).	Preventivo: TLS 1.2+ obligatorio; dispositivos administrados y conformes; validaciones de negocio y límites de aprobación; endurecimiento del navegador. Detectivo: Alertas de EDR en endpoints; reglas de anomalía en montos y beneficiarios. Correctivo: Aislar el equipo, revertir o ajustar las transacciones y reforzar la sesión del usuario.

F1-08 Órdenes de compra y datos de proveedor (Flujo de datos)

Descripción: Órdenes de compra y datos de proveedor

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-09 Configuración, roles y seguridad (Flujo de datos)

Descripción: Configuración, roles y seguridad

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-10 Confirmaciones de OC y facturas (Flujo de datos)

Descripción: Confirmaciones de OC y facturas

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
15	T15 [Medio] Interceptación de datos en tránsito desde proveedores en Internet	Information disclosure	Media	Abierto		El tráfico de proveedores sobre redes no confiables podría exponerse si hay configuraciones TLS débiles o equipos comprometidos. (Impacto: Medio; Probabilidad: Media; Riesgo: Medio).	Preventivo: TLS 1.2+ (gestionado por el servicio); HSTS; acceso condicional para externos; guía de seguridad para proveedores. Detectivo: Alertas de inicios de sesión desde ubicaciones inusuales. Correctivo: Restablecer credenciales de la cuenta externa y revisar la información accedida.
16	T16 [Medio] Abuso o fuerza bruta contra el portal de proveedores	Denial of service	Media	Abierto		Intentos masivos de inicio de sesión o llamadas automatizadas degradan el portal o bloquean cuentas legítimas. (Impacto: Medio; Probabilidad: Media; Riesgo: Medio).	Preventivo: Bloqueo inteligente (smart lockout); límites de tasa; acceso condicional; listas de IP permitidas para integraciones. Detectivo: Alertas por picos de fallos de autenticación. Correctivo: Bloquear orígenes maliciosos y desbloquear cuentas legítimas tras validación.

F1-11 Lectura/escritura de datos financieros (Flujo de datos)

Descripción: Lectura/escritura de datos financieros

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-12 Lectura/escritura de datos de compras (Flujo de datos)

Descripción: Lectura/escritura de datos de compras

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-13 Lote de pago aprobado (OData) (Flujo de datos)

Descripción: Lote de pago aprobado (OData)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-14 Instrucciones de pago, acuses y extractos (Flujo de datos)

Descripción: Instrucciones de pago, acuses y extractos

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-15 Extractos y asientos de conciliación (Flujo de datos)

Descripción: Extractos y asientos de conciliación

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-16 Certificados y credenciales (Flujo de datos)

Descripción: Certificados y credenciales

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-17 Registros de auditoría (Flujo de datos)

Descripción: Registros de auditoría

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-18 Registros de integración (Flujo de datos)

Descripción: Registros de integración

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-19 Datos financieros para reportes (Flujo de datos)

Descripción: Datos financieros para reportes

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-20 Modelo semántico (Flujo de datos)

Descripción: Modelo semántico

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F1-21 Consulta de reportes (Flujo de datos)

Descripción: Consulta de reportes

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

DFD Nivel 2 - Integración bancaria

EE07 Aprobador de pagos (Tesorería) (Actor)

Descripción: Aprueba los lotes de pago antes de su envío.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
28	T28 [Alto] El aprobador niega haber autorizado un lote de pago	Repudiation	Alta	Abierto		Sin evidencia vinculante, un aprobador puede negar su autorización. (Impacto: Alto; Probabilidad: Media; Riesgo: Alto).	Preventivo: Aprobación con identidad nominal y MFA; registro inmutable de aprobación vinculado al hash del lote; flujo de doble aprobación. Detectivo: Revisión de bitácoras de aprobación; conciliación entre aprobaciones y pagos enviados. Correctivo: Reconstruir la evidencia desde logs y ajustar los flujos de aprobación.

EE06 Banco (Actor)

Descripción: Recibe instrucciones de pago y entrega extractos.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
27	T27 [Medio] Suplantación del endpoint del banco en el canal de transmisión	Spoofing	Media	Abierto		Un endpoint falso (por DNS o configuración errónea) recibe instrucciones de pago o devuelve acuses falsos. (Impacto: Crítico; Probabilidad: Baja; Riesgo: Medio).	Preventivo: mTLS con validación del certificado del banco; fijación de certificados (pinning); endpoints fijos y verificados. Detectivo: Alertas por cambios de endpoint o errores de validación de certificado. Correctivo: Suspender envíos, validar el canal con el banco y rotar credenciales.

P02.1 D365 F&O - Pagos y conciliación (Proceso)

Descripción: Subproceso de Finanzas: genera lotes de pago y contabiliza conciliaciones.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P04.1 Azure Logic Apps (orquestador) (Proceso)

Descripción: Recibe el lote aprobado y orquesta el envío.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
24	T24 [Alto] Invocación no autorizada del flujo de Logic Apps	Spoofing	Alta	Abierto		Si el desencadenador HTTP usa una URL con firma (SAS) expuesta, cualquiera que la conozca puede iniciar el flujo de pago. (Impacto: Crítico; Probabilidad: Media; Riesgo: Alto).	Preventivo: Autenticación con Entra ID (OAuth) en el desencadenador; restricción de IP de entrada; API Management; tratar las URL del trigger como secretos. Detectivo: Alertas por ejecuciones fuera de horario o de origen desconocido. Correctivo: Regenerar las claves del trigger, deshabilitar el flujo y revisar las ejecuciones recientes.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
31	T31 [Medio] Agotamiento de límites de ejecución por reintentos masivos	Denial of service	Media	Abierto		Reintentos descontrolados saturan el flujo y retrasan los pagos. (Impacto: Medio; Probabilidad: Media; Riesgo: Medio).	Preventivo: Políticas de reintento con backoff; límites de concurrencia; alertas de capacidad. Detectivo: Métricas de ejecuciones fallidas y latencia. Correctivo: Pausar los reintentos, depurar la cola y reprocesar de forma controlada.

P04.2 Azure Service Bus (Proceso)

Descripción: Cola de mensajes de pago con reintentos y DLQ.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
23	T23 [Alto] Inyección de mensajes de pago falsos en Service Bus	Tampering	Alta	Abierto		Un actor con claves de acceso compartido (SAS) o permisos amplios puede publicar mensajes de pago que no se originaron en D365. (Impacto: Crítico; Probabilidad: Media; Riesgo: Alto).	Preventivo: Autenticación con Entra ID/RBAC sin SAS; private endpoints; deshabilitar acceso público; validar origen y firma del mensaje. Detectivo: Alertas por mensajes de origen desconocido; monitoreo de métricas de la cola. Correctivo: Rotar o deshabilitar claves, purgar mensajes sospechosos y revisar los pagos generados.

P04.3 Conector bancario (firma y cifrado) (Proceso)

Descripción: Firma, cifra y transmite instrucciones; recibe acuses y extractos.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
25	T25 [Crítico] Exposición de datos de pago en el historial de ejecución	Information disclosure	Crítica	Abierto		Los datos de entrada y salida de las acciones (IBAN, montos, beneficiarios) quedan visibles en el historial de ejecuciones para quienes tienen acceso de lectura. (Impacto: Alto; Probabilidad: Alta; Riesgo: Crítico).	Preventivo: Activar entradas y salidas seguras (secure inputs/outputs); RBAC restringido al historial; enmascaramiento; retención mínima. Detectivo: Revisión de accesos al historial de ejecuciones; alertas de lectura masiva. Correctivo: Purgar el historial afectado y corregir la configuración.
26	T26 [Alto] Uso indebido de la clave de firma por una identidad no autorizada	Elevation of privilege	Alta	Abierto		Una identidad con permisos de uso de la clave o certificado puede firmar instrucciones de pago propias. (Impacto: Crítico; Probabilidad: Media; Riesgo: Alto).	Preventivo: Permisos de firma solo para la identidad del conector; claves no exportables (HSM / Key Vault Premium); aprobación para cambios de acceso. Detectivo: Alertas por operaciones de firma fuera de patrón; revisión de asignaciones de roles de Key Vault. Correctivo: Revocar el acceso, rotar la clave y notificar al banco.

DS02 Azure Key Vault (Dispositivo de almacenamiento)

Descripción: Certificado de firma y credenciales bancarias.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

DS03 Log Analytics / SIEM (Dispositivo de almacenamiento)

Descripción: Registros de ejecución y auditoría.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

DS05 Almacenamiento temporal (Blob) (Dispositivo de almacenamiento)

Descripción: Extractos bancarios recibidos antes de conciliar.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
29	T29 [Medio] Alteración de extractos bancarios en el almacenamiento temporal	Tampering	Media	Abierto		Modificación de extractos para ocultar pagos fraudulentos durante la conciliación. (Impacto: Alto; Probabilidad: Baja; Riesgo: Medio).	Preventivo: Almacenamiento inmutable (WORM); hash del archivo recibido; private endpoint; acceso mínimo. Detectivo: Comparación de hashes y de saldos con el banco. Correctivo: Volver a descargar el extracto del banco y reprocesar.

P04.4 Procesador de extractos y conciliación (Proceso)

Descripción: Transforma extractos y genera asientos de conciliación.

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
30	T30 [Medio] Reglas de conciliación débiles permiten ocultar pagos fraudulentos	Tampering	Media	Abierto		Coincidencias automáticas laxas pueden marcar como conciliados pagos no autorizados. (Impacto: Alto; Probabilidad: Baja; Riesgo: Medio).	Preventivo: Reglas de coincidencia estrictas (monto, fecha, beneficiario); revisión manual de excepciones; SoD entre quien paga y quien concilia. Detectivo: Reporte de partidas conciliadas automáticamente con baja certeza. Correctivo: Revisar las conciliaciones del periodo y ajustar las reglas.

F2-01 Aprobación de lote de pago (Flujo de datos)

Descripción: Aprobación de lote de pago

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2-02 Lote de pago aprobado (OData) (Flujo de datos)

Descripción: Lote de pago aprobado (OData)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
22	T22 [Alto] Alteración del lote de pago aprobado (beneficiario, monto o cuenta)	Tampering	Alta	Abierto		El lote aprobado en D365 puede modificarse en tránsito o en el middleware antes de llegar al banco. (Impacto: Crítico; Probabilidad: Media; Riesgo: Alto).	Preventivo: Hash o firma del lote en origen y verificación en el conector; TLS; comparación de totales de control; mínimo privilegio sobre Logic Apps. Detectivo: Conciliación de totales entre D365, middleware y banco; alertas por discrepancias. Correctivo: Bloquear el lote, solicitar la devolución al banco e investigar el punto de alteración.

F2-03 Mensaje de pago (Flujo de datos)

Descripción: Mensaje de pago

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2-04 Mensaje de pago (Flujo de datos)

Descripción: Mensaje de pago

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2-05 Solicitud de firma / certificado (Flujo de datos)

Descripción: Solicitud de firma / certificado

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2-06 Instrucción de pago firmada (Flujo de datos)

Descripción: Instrucción de pago firmada

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2-07 Acuse de estado y extracto (Flujo de datos)

Descripción: Acuse de estado y extracto

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2-08 Extracto bancario (Flujo de datos)

Descripción: Extracto bancario

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2-09 Extracto para conciliación (Flujo de datos)

Descripción: Extracto para conciliación

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2-10 Asientos de conciliación (Flujo de datos)

Descripción: Asientos de conciliación

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F2-11 Registros de ejecución (Flujo de datos)

Descripción: Registros de ejecución

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones